

Find All the potential Impact if Compromise
(What can the attacker do?)

- Direct Trust / Access
- - - Indirect / Transitive Trust
- ★ Leverage Point (Sp. Layer)
- △ Potential Misalignment
- - - - - Cross-Account / External Boundary

(4)
★ Leverage point:
Only as secure as
the permissions written

IAM
User/
Role

or

IAM
Policy
Eval

AWS
Services

assumes

Execution
Role
(IAM role)

or

Anonymous/
Public

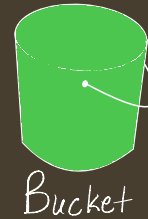
(1)
★ Leverage point:
- Attacker compromises the service
- Role grants access beyond just S3
- Can move services to service
- Potentially full account compromise

Bucket Policy

(Principle: "*)

(2)
★ Leverage point:
- No account needed
- Attacker can access anything
in the bucket
- Unlimited - lists, downloads,
potentially delete all objects

S3



Bucket

objects

(3)
★ Leverage point:
- Old objects remain public ACL
- Small number of S3 buckets containing data
- Bucket level can't secure but objects are encrypted
- S3 itself - no one checks